Room - Nmap the basics

Manually discovering live devices on a network and identifying their services is slow and inefficient. Basic tools like ping and arp-scan have limitations, such as being blocked by firewalls or only working within the same network. Similarly, checking open ports manually (for example using telnet) is time-consuming due to the large number of ports.

To solve these problems, **Nmap** is used. It is a powerful and flexible open-source network scanner that can efficiently discover live hosts and identify services running on them.

Host Discovery

arget Specification in Nmap

Nmap allows multiple ways to define targets:

- **IP Range** → `192.168.0.1-10`
- **Subnet** → `192.168.0.1/24`
- **Hostname** → example.thm

🔍 Discovering Live Hosts (`-sn`)

- `-sn` → Ping scan (only finds live hosts, no port scanning)
- Requires root/sudo for full capability

🏠 Scanning a Local Network

- Example: `nmap -sn 192.168.x.0/24`
- Nmap uses **ARP requests**
- If a device responds → marked as **"Host is up"**

Extra benefit:

- Shows **MAC address**
- Can identify **device vendor**

🌐 Scanning a Remote Network

- Cannot use ARP (because routers are in between)
- Nmap uses multiple methods:
  - ICMP echo requests (ping)
  - ICMP timestamp requests
  - TCP SYN packets (port 443)
  - TCP ACK packets (port 80)

👉 If the host responds → it is considered alive
👉 If no response → host may be down or blocking traffic

⚙️ Advanced Host Discovery Options

- `-PS` → TCP SYN scan
- `-PA` → TCP ACK scan
- `-PU` → UDP scan

(Not deeply covered, but gives more control)

📋 List Scan (`-sL`)

- Lists targets **without scanning**

nmap -sL 192.168.0.1/24

👉 Useful to verify targets before scanning

🔇 Important Note about `-sn`

- Only discovers **live hosts**
- Does **NOT** detect services
- Low noise scan

👉 For service detection → need more aggressive scans

Port scanning

- Find **which services are running** on live hosts
- A service = any process listening on a **TCP or UDP port**
- Example:
  - Web → ports 80, 443
  - DNS → port 53

🔢 Key Fact

- TCP ports: 1 to 65,535
- UDP ports: 1 to 65,535

So yes, checking all manually would be a terrible life choice.

🔍 TCP Port Scanning

1. Manual idea (inefficient)

- Try connecting using Telnet to each port
- Only open ports respond successfully

👉 Works, but painfully slow

---

2. Connect Scan (`-sT`)

- Completes full TCP three-way handshake:
  - SYN → SYN-ACK → ACK
- If successful → port is **open**
- Nmap then closes connection (RST)

Behavior:

- Open port → connection established
- Closed port → target sends RST

👉 Reliable but:

- Easy to detect (not stealthy)

---

3. SYN Scan (`-sS`) – Stealth Scan

- Sends only **SYN**
- Does NOT complete handshake

Behavior:

- Open port → SYN-ACK → Nmap sends RST
- Closed port → RST

👉 Advantages:

- Faster
- Less detectable
- No full connection established

🔍 UDP Port Scanning (`-sU`)

- UDP is connectionless (no handshake)

Behavior:

- Closed port → ICMP “port unreachable”
- Open port → usually no response

👉 Slower and less reliable than TCP scanning
👉 Still important (DNS, DHCP, NTP, etc.)

⚙️ Limiting Ports to Scan

By default:

- Nmap scans **top 1000 common ports**

Options:

- `-F` **(Fast mode)**
  → scans top **100 ports**

- `-p[range]`
  → specify ports manually
  - `-p10-1024` → ports 10 to 1024
  - `-p-25` → ports 1 to 25
  - `-p-` → all ports (1–65535)

Option	Explanation
`-sT`	TCP connect scan – complete three-way handshake
`-sS`	TCP SYN – only first step of the three-way handshake
`-sU`	UDP scan
`-F`	Fast mode – scans the 100 most common ports
`-p[range]`	Specifies a range of port numbers – `-p-` scans all the ports

Version Detection

OS Detection (`-O`)

- `-O` enables **operating system detection**
- Nmap analyzes responses (TTL, packet behavior, etc.) to **guess the OS**
- Output shows:
  - OS type (e.g., Linux)
  - Possible versions (e.g., 4.x or 5.x)

👉 Important:

- It is **not perfectly accurate**
- Gives an **educated guess**, not exact version

🔍 Service & Version Detection (`-sV`)

- `-sV` identifies:
  - **What service is running** (e.g., SSH)
  - **Exact version** (e.g., OpenSSH 8.9)
- Adds a **VERSION column** in output

👉 Useful for:

- Understanding target system
- Finding vulnerabilities

⚙️ Aggressive Scan (`-A`)

- Combines multiple features:
  - OS detection (`-O`)
  - Version detection (`-sV`)
  - Traceroute
  - Other advanced checks

👉 One command for maximum information
👉 More detailed but also **more detectable**

🚫 Forcing the Scan (`-Pn`)

- Normally:
  - Nmap first checks if host is alive
  - If no response → assumes host is down
- `-Pn`:
  - Skips host discovery
  - Treats all hosts as **online**
  - Forces port scanning anyway

👉 Useful when:

- ICMP is blocked
- Host appears “down” but is actually alive

Timing

Option	Explanation
`-T<0-5>`	Timing template – paranoid (0), sneaky (1), polite (2), normal (3), aggressive (4), and insane (5)
`--min-parallelism <numprobes>` and `--max-parallelism <numprobes>`	Minimum and maximum number of parallel probes
`--min-rate <number>` and `--max-rate <number>`	Minimum and maximum rate (packets/second)
`--host-timeout`	Maximum amount of time to wait for a target host

Verbosity (`-v`)

- `-v` shows **more real-time information** about the scan
- Displays:
  - Scan stages (ARP scan, DNS resolution, SYN scan)
  - Progress updates
  - Discovered hosts and ports

👉 More `v` = more detail:

- `-vv`, `-vvv`, etc.
- Or directly: `-v2`, `-v4`

👉 You can even press **`v` during the scan** to increase verbosity

---

🔍 Debugging (`-d`)

- `-d` gives **deep internal details**
- Shows:
  - Packet-level behavior
  - Internal decisions of Nmap

👉 Levels:

- `-d`, `-dd`, … up to `-d9`

⚠️ High levels = **massive output (very noisy)**

💾 Saving Scan Results

Nmap allows saving results in different formats:

- `-oN <file>` → Normal (human-readable)
- `-oX <file>` → XML (structured data)
- `-oG <file>` → Grepable (for scripting)
- `-oA <name>` → Saves all formats together

👉 Example:

nmap -oA scan_result target

Creates:

- `scan_result.nmap`
- `scan_result.xml`
- `scan_result.gnmap`